

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Desde la Perspectiva Doméstica
 - Recomendaciones básicas de uso del sistema
 - Protección física
 - Configuración y Actualizaciones del Sistema y de las Aplicaciones
 - **Utilizar cuentas de usuario y Administrador; Política de Contraseñas; Configuración de Actualizaciones automáticas; Política de Copias de Seguridad**
 - Conexión a Internet. ADSL y redes WIFI
 - Recomendaciones Básicas
 - **CAMBIAR CONTRASEÑA de acceso** al router y evitar acceso desde Internet; **Asegurarnos** de que estamos en “**modo firewall**”; Evitar “default workstation o DMZ”; Ocultar el SSID; Empleo de Protocolos seguros (**WPA** /2 /3 frente a WEP) y **CAMBIAR la CONTRASEÑA WIFI**; Utilizar ACL por MAC; Desactivación del DHCP y uso de IP estáticas; Posibilidad de usar 802.1X / Radius
 - Protección contra el malware. Suites de seguridad
 - Es **IMPRESINDIBLE** instalar una buena “**suite**” (puede ser gratuita o la propia del sistema operativo) y **escaneos periódicos remotos** con otra suite
 - Recomendaciones en el empleo de dispositivos móviles
 - **Protección información almacenada** (cifrado, copias seguridad); en **tránsito** (cifrado); **Wifi** (cifrado sed pública); **Bluetooth** (peligroso); **Malware** (instalar suite); Controlar **permisos de las aplicaciones**.

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Seguridad en el uso del Correo Electrónico
 - Recomendaciones generales
 - Utilización de **varias cuentas**
 - Consultarlas periódicamente
 - Configurar las opciones de Spam (correo no deseado)
 - Empleo del **correo seguro** (S/MIME o PGP) para envío de información confidencial
 - Recomendaciones específicas para la recepción
 - **No abrir** correos de origen sospechoso
 - **Jamás responder** a SPAM
 - **Jamás hacer click en un enlace** a sitio web donde pidan **credenciales**
 - **No descargar** adjuntos de origen poco fiable y **ESCANEAR** todo adjunto; **Desconfiar** del remitente... puede ser falso o estar infectado.
 - Utilizar **filtros** anti-spam
 - **Evitar** toda URL sospechosa... mucho mejor acceder nosotros y navegar...
 - Recomendaciones específicas para el envío
 - Utilizar **"Asunto"** descriptivo
 - No proporcionar **información personal** o financiera
 - **No responder** a SPAM (salvo para intentar borrarse de la lista – Robinson?)
 - **No participar en cadenas** de mensajes (pásalo)
 - Utilizar el **campo CCO:** (Bcc) al enviar mensajes a varios destinatarios.

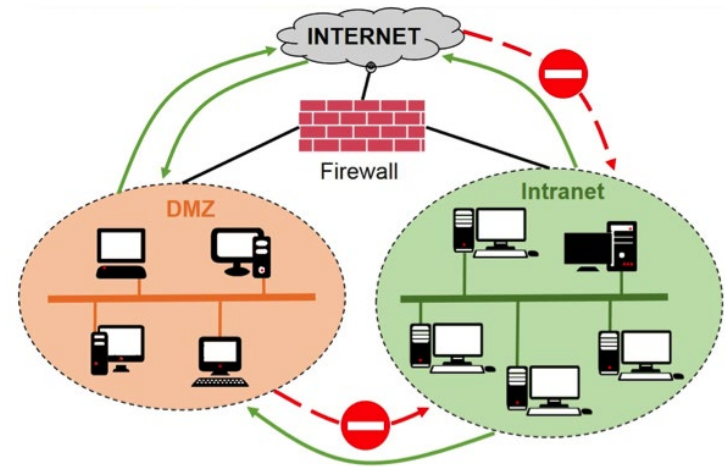
Unidad de Aprendizaje 4: Mecanismos de Defensa

- Navegación segura (ordenador y móvil)
- Recomendaciones empleo Web, RRSS y comercio electrónico
 - **Actualización continua Navegadores**
 - No acceder a **URLs no fiables** (instalación productos, Phising, etc.)
 - Cuidado con Google (Black Hat SEO) – nos puede llevar a sitios tóxicos
 - Evitar “**recordar contraseñas**”; Control de “**Cookies**”
 - Verificación **envío de datos sensibles** a través de SSL/TLS (web segura)
 - Asegurarnos de que el sitio web tiene certificado digital válido
 - Utilizar **autenticación de dos factores** siempre que sea posible (bancos, etc.)
 - Evitación de Código Tóxico y control de pestañas (no red social y banco a la vez)
 - “**Googlear**” **toda URL sospechosa** antes de acceder.
- Uso racional de la Privacidad en Redes Sociales
 - TODO LO INDICADO ANTERIORMENTE MÁS:
 - Política de Uso y Privacidad
 - Nivel de Privacidad
 - **Evitar acceso a “amigos de los amigos”**
 - Verificar que se cumple lo indicado
 - Información Personal
 - Información de Terceros

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Protegiendo la organización: defensa perimetral

- Frontera de contención: Firewalls
 - 3 niveles operación: red, transporte y aplicación
- Zona desmilitarizada: DMZ
 - Contiene los bastiones (servidores externos)
 - Sujeta a ataques, bastiones bajo sospecha
- Intranet Corporativa
 - Zona segura en el interior de la organización
 - Filtra accesos desde DMZ e Internet
- Acceso Seguro a la Intranet: VPN
 - Posibilidad acceso cifrado a redes no seguras
- Detección de intrusos: Correlación e IDS
 - Análisis logs servidores y patrones de tráfico
 - Intrusion detection Systems
- IPS (Intrusion Prevention Systems)
 - Configuran el Firewall para impedir accesos en TR
 - Habitualmente son extensiones de un IDS
- Hacking ético, análisis de seguridad y Pentests
 - Garantizar inmunidad ante ataques – ataques preventivos
 - Empleo de herramientas OSINT (Open Source Intelligence)
 - Análisis de caja blanca, caja negra o caja gris
 - Análisis Forense (equipos activos) o Post-mortem (no activos)



Unidad de Aprendizaje 4: Mecanismos de Defensa

- Seguridad en servidores Web – OWASP
- Open Worldwide Application Security Project – owasp.org
 - Fundación non-profit dedicada a mejorar la seguridad del software
 - Recursos públicos y de libre acceso
 - OWASP ASVS (Application Security Verification Standard)
 - Estándar de requisitos de seguridad en apps web
 - Guía de referencia actual 5.0.0 (2025) – 17 apartados, metodología de análisis
 - OWASP WSTG (Web Security Testing Guide)
 - Guía de pruebas para auditoría de apps web – cheklists de control, metodología
 - Versión actual 5.0.0 (2025) – descarga desde sitio Github
 - OWASP API Security Top 10
 - Riesgos de seguridad en APIs – exponen lógica del negocio y datos personales
 - Versión actual: 2023
 - OWASP Top 10 – Lista (cada 4 años) de Riesgos críticos en apps web

▪ Edición actual: 2025

A01 – Control de Acceso roto	A02 – Configuración de seguridad incorrecta
A03 – Fallos en cadena de suministro software	A04 – Fallos criptográficos
A05 – Inyección de código	A06 – Diseño inseguro
A07 – Fallos de autenticación	A08 – Fallos de integridad de software o datos
A09 – Fallos de registro y alerta de seguridad	A10 – Gestión incorrecta de excepciones

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Seguridad en servidores Web – WAF (Web Application Firewall)
 - WAF – Software de monitorización, filtrado y bloqueo de tráfico web malicioso
 - Opera a nivel 7 OSI – Firewalls operan en niveles 3 y 4
 - Modelos de detección
 - Lista Negra (blacklist) – bloquea patrones conocidos de ataque (SQLi, XSS, etc.)
 - Lista Blanca (whitelist) – sólo permite tráfico que cumple comportamiento esperado
 - Modelo Mixto (blacklist/whitelist) – el más comúnmente usado
 - Modos de operación
 - Detección/Monitorización – registra y alerta sin bloquear – útil en despliegue y puesta a punto
 - Prevención y bloqueo – Intercepta y descarga peticiones maliciosas en tiempo real
 - Formas de despliegue
 - Proxy inverso: el WAF recibe el tráfico y lo reenvía al servidor – forma más habitual
 - Modo inline (transparente) – insertado físicamente en el flujo de red
 - Port mirroring (SPAN) – analiza copia del tráfico, no bloquea en tiempo real
 - Servidor único vs. Cluster
 - WAF en el mismo servidor o en nodo dedicado, simple pero sin redundancia/escalabilidad
 - Cluster – varios WAF en paralelo – balanceo de carga, redundancia – exige sincronización reglas
 - Cloud WAF – SaaS gestionado por proveedor – sencillo pero se cede tráfico a tercero
 - Problema crítico: descifrado TLS previo al análisis
 - Si el WAF no está integrado, descifrado – análisis – reenvío al servidor (recifrado de nuevo?)
 - El WAF actúa como “man-in-the-middle” legal y ha de tener certificado propio
 - Introduce latencia y requiere gestión de certificados adicionales
 - En cluster, el punto de descifrado ha de estar centralizado/replicado – mayor complejidad

Unidad de Aprendizaje 4: Mecanismos de Defensa

- ModSecurity – el WAF de código abierto de referencia
 - Qué es ModSecurity
 - WAF Open Source – inicialmente Apache, ahora Nginx, IIS, etc – referente mundial
 - Opera interceptando peticiones y respuestas HTTP/HTTPS
 - Lenguaje de reglas propio - SecLang
 - Estado actual del proyecto
 - Desarrollado por Trustwave, desde 2024 bajo el mando de **OWASP Foundation**
 - OWASP gestiona ModSecurity, Coraza (en Go) y el OWASP Core Rule Set (CRS)
 - CRS cubre los ataques de OWASP Top 10: SQLi, XSS, inyección de código, etc.
 - Arquitectura y uso
 - Servidor único: módulo del servidor web Mod_security (Apache) modsecurity-nginx (Nginx), etc.
 - En cluster: sincronización de reglas entre los frontales
 - Trabaja como Proxy inverso: recibe todo el tráfico y lo reenvía al servidor
 - Retos operativos
 - Falsos positivos: reglas muy estrictas bloquean tráfico legítimo, si son laxas: ataques – ajuste continuo
 - Descifrado TLS: si es en diferente servidor: certificados y recifrado – gestión
 - Mantenimiento del CRS: las reglas han de actualizarse continuamente – nuevas vulnerabilidades
 - Rendimiento: el análisis introduce latencia, en cluster: balanceo y recursos dedicados
 - Conceptos clave:
 - Un WAF no sustituye al desarrollo seguro ni al parcheo de vulnerabilidades
 - Es una capa de protección adicional (parche virtual) que reduce ventana de exposición mientras se aplican correcciones definitivas

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Protección desde la perspectiva gubernamental
 - Agencia Europea de seguridad de las redes de información (ENISA)
 - Creada en 2004 (Grecia), desde 2018 responsable de ciberseguridad en la UE (Directiva NIS)
 - Desarrollo de estrategias de ciberseguridad nacional
 - Estudios sobre desarrollo tecnológico y ciberseguridad
 - Organización de ciberejercicios para comprobar ciberseguridad a gran escala
 - Mando Conjunto de Ciberdefensa
 - Creado en 2014, organismo militar auxiliar del JEMAD
 - Responsable del planeamiento y ejecución de la ciberdefensa en el entorno militar
 - Garantizar funcionamiento sistemas defensa
 - Analizar ciberindicentes bajo su responsabilidad
 - SOCs
 - Security Operation Center – monitorizan y protegen organismos 24x7x365
 - SOC AGE (CCN) – ámbito en la Administración General del Estado
 - CERT y CSIRT
 - Centros de respuesta ante incidentes – Coordinan la respuesta ante incidentes de seguridad
 - RD 12/2018 (directiva NIS) asigna competencias a tres CERTS/CSIRTS:
 - CCN/CERT (Admón pública) ; ESP DEF CERT (Defensa) e INCIBE-CERT (empresas, red académica y ciudadanos)
 - Existen otros CERT de ámbito público (autonómicos) y privado que hacen de primer escalón

Unidad de Aprendizaje 4: Mecanismos de Defensa

- Protección desde la perspectiva gubernamental
 - Centro Criptológico Nacional (CCN)
 - Creado en 2004, adscrito al CNI; Coordina acción organismos Admón que utilizan técnicas de cifrado
 - Garantizar seguridad Tis; Informa adquisiciones; formación personal; opera el CCN-CERT
 - Ámbito: Sistemas Admón; Seguridad y Defensa; Infraestructuras Críticas y Sectores Estratégicos; Ciudadanos y Pymes
 - Funciones: CERT, elaborar normas, guías, etc; Formación personal; Certificar cumplimiento ENS
 - Centro Nacional de Protección de Infraestructuras Críticas (CNPIC)
 - 2007 – responsable de la protección e impulso de todas las infraestructuras críticas en España
 - Objetivos: desarrollo de planes estratégicos de los 12 sectores y creación y custodia del Catálogo Nacional de Infraestructuras Críticas
 - INCIBE (antes INTECO)
 - Investigación aplicada y formación en Ciberseguridad – opera el INCIBE-CERT
 - Gestión y soporte de incidentes, asesoría legal, laboratorio de soluciones de seguridad
 - Desarrollo herramientas ciberseguridad
 - OSI (Oficina Seguridad Internauta) – reforzar la confianza del ciudadano - Guías, cursos, etc.
 - Agencia Española de Protección de Datos (AEPD)
 - Cumplimiento legislación Protección de Datos (LOPD 1999 LOPDYGDD 2018)
 - Ámbito nacional, existen agencias autonómicas en Madrid, Cataluña y el País Vasco
 - Funciones: Cumplimiento ley, afectados (solicitudes); Tratamiento (autorizaciones); Medidas correctivas (Sanciones); Transferencias internacionales
 - Nueva Ley (2018) – Enfoque orientado al tratamiento de los datos (no registro ficheros)
 - En su web, ayuda cumplimiento, multitud de Guías, herramientas para análisis de impacto, etc.